

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha: 16/07/2025
- Entorno: Windows Server 2019

○ IP-> 192.168.88.143

OBJETIVO Y ALCANCE

- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows Server 2019** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- El análisis de seguridad realizado sobre el sistema **Windows Server 2019** ha revelado la exposición de varios servicios críticos y una configuración que incrementa la superficie de ataque del sistema. Entre los hallazgos más relevantes se encuentran:
- El servicio **SMBv2 activo en el puerto 445**, históricamente vinculado a vulnerabilidades graves como EternalBlue.
- **Servicios RPC abiertos en múltiples puertos**, que pueden facilitar la enumeración de información sensible o ser aprovechados como vector de movimiento lateral.
- La **exposición del protocolo RDP**, que podría permitir intentos de acceso remoto no autorizado si no está protegido adecuadamente.
- La **presencia de NetBIOS**, lo que habilita mecanismos de descubrimiento e identificación de recursos compartidos.
- Aunque se trata de un sistema moderno, algunas configuraciones por defecto, combinadas con la exposición de servicios ampliamente atacados, elevan el riesgo general del entorno si no se aplican controles adecuados.

CLASIFICACIÓN DE VULNERABILIDADES

- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.

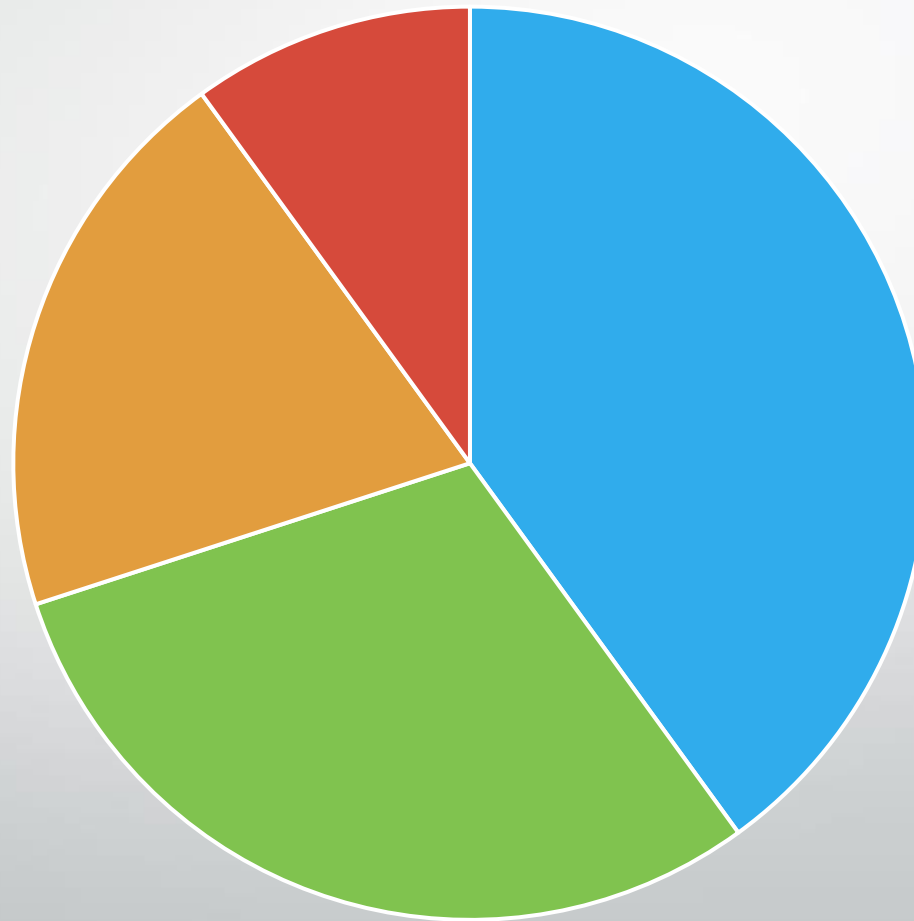


TABLA DE VULNERABILIDADES

Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	22	SSH	Permite el acceso remoto a la línea de comandos del sistema. La vulnerabilidad más crítica aquí es la existencia de credenciales débiles .	CVE-2018-15473.	-Fortalecer contraseñas. -Autenticación por claves SSH. -Autenticación Multifactor. -Limitar acceso
Alto	445	SMB	Se utiliza para la compartición de archivos, impresoras y para la comunicación entre procesos en sistemas Windows	-CVE-2017-0144 -CVE-2020-0796	-Deshabilitar SMBv1 -Firmado SMB -Permisos estrictos. -Firewall. -Actualizaciones y parches
Medio	135	MSRPC	Permite comunicación entre procesos en sistemas Windows.es un vector común para la enumeración de información del sistema	CVE-2021-1675	-Segmentar redes. -Actualizaciones y parches. Principio de mínimo privilegio
Bajo	80	Microsoft IIS httpd 10	permiten robar cookies o información de cabeceras HTTP si el navegador y las condiciones de red lo permiten	CVE-2004-2320	Deshabilitar el método TRACE en la configuración del servidor web. Verificar los métodos habilitados y restringir únicamente a los necesarios

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 22 ■ Puerto 445 ■ Puerto 135 ■ Puerto 80

RECOMENDACIONES

- **Aplicar los parches de seguridad críticos del sistema operativo**, especialmente aquellos relacionados con los servicios SMB, RDP y MSRPC.
- **Restringir el acceso a puertos críticos** (445, 3389, 135, etc.) mediante firewall y segmentación de red, limitando su visibilidad solo a redes internas confiables.
- **Habilitar la Autenticación a Nivel de Red (NLA)** en RDP y complementar con mecanismos de doble factor (MFA) siempre que sea posible.
- **Deshabilitar servicios innecesarios o inseguros**, como NetBIOS, si no son requeridos por el entorno operativo.
- **Fortalecer las políticas de contraseñas y autenticación**, especialmente en cuentas de administración o servicio.
- **Monitorear la actividad de red y del sistema en tiempo real**, implementando soluciones de detección de amenazas (EDR/SIEM).
- **Auditar periódicamente la exposición de servicios y configuraciones**, especialmente tras actualizaciones, nuevos despliegues o cambios en la red.
- **Formar y sensibilizar al equipo técnico** sobre buenas prácticas de ciberseguridad y gestión de servidores Windows.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – SSH

- **Puerto:** 22
- **Nivel de riesgo:** Crítico
- **Recomendación:**
 - Fortalecer contraseñas.
 - Autenticación por claves SSH.
 - Autenticación Multifactor.
 - Limitar acceso
- **Descripción:**
 - El servicio SSH permite el acceso remoto al sistema operativo a través de una terminal segura. En este caso, el servicio OpenSSH está activo y expuesto públicamente, y se ha podido acceder exitosamente usando credenciales válidas del usuario administrador del dominio . Esto representa un riesgo crítico, ya que otorga control total del sistema a través de un canal cifrado.

Password for [TSS\administrador]:

Sharename	Type	Comment
ADMIN\$	Disk	Admin remota
C\$	Disk	Recurso predeterminado
IPC\$	IPC	IPC remota
NETLOGON	Disk	Recurso compartido del servidor de inicio de sesión
Recursos empresa	Disk	
SYSVOL	Disk	Recurso compartido del servidor de inicio de sesión

Reconnecting with SMB1 for workgroup listing.

EVIDENCIA N° 2 – Servicio SMB activo

- **Puerto:** 445
- **Nivel de riesgo:** Alto
- **Recomendación:**
 - Deshabilitar SMBv1
 - Firmado SMB
 - Permisos estrictos.
 - Firewall.
 - Actualizaciones y parches
- **Descripción:**
 - El puerto 445 se encuentra abierto con el servicio Microsoft SMB activo. Este protocolo ha sido históricamente vulnerable a ejecución remota de código si no está parcheado, como es el caso de CVE-2009-3103.

Password for [TSS\administrador]:

Sharename	Type	Comment
ADMIN\$	Disk	Admin remota
C\$	Disk	Recurso predeterminado
IPC\$	IPC	IPC remota
NETLOGON	Disk	Recurso compartido del servidor de inicio de sesión
Recursos empresa	Disk	
SYSVOL	Disk	Recurso compartido del servidor de inicio de sesión

Reconnecting with SMB1 for workgroup listing.

EVIDENCIA N° 3 – Servicio MSRPC expuesto

- **Puerto:** 135
- **Nivel de riesgo:** Medio
- **Recomendación:**
 - Segmentar redes.
 - Actualizaciones y parches.
 - Principio de mínimo privilegio
- **Descripción:**
 - El puerto 135 está abierto con el servicio MSRPC activo. Este puerto permite llamadas a procedimientos remotos y puede servir como puerta de entrada para ataques como PrintNightmare (CVE-2021-1675) si no se encuentra correctamente parcheado.

```
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.88.143 ) =====
[+] Got domain/workgroup name: TSS

===== ( Nbtstat Information for 192.168.88.143 ) =====
Looking up status of 192.168.88.143
TSS <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
CONTROLADORDOM <00> - <GROUP> M <ACTIVE> Workstation Service
TSS <1c> - <GROUP> M <ACTIVE> Domain Controllers
CONTROLADORDOM <20> - <GROUP> M <ACTIVE> File Server Service
TSS <1b> - <GROUP> M <ACTIVE> Domain Master Browser

MAC Address = 00-0C-29-F4-AD-AE

===== ( Session Check on 192.168.88.143 ) =====
[+] Server 192.168.88.143 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.88.143 ) =====
Domain Name: TSS
Domain Sid: S-1-5-21-765635370-698130357-804349127
```

EVIDENCIA N° 4 – HTTP TRACE Habilitado

- **Puerto:** 80
- **Nivel de riesgo:** Bajo
- **Recomendación:**
 - Deshabilitar el método TRACE en la configuración del servidor web. Verificar los métodos habilitados y restringir únicamente a los necesarios
- **Descripción:**
 - Se observa que el servidor web IIS tiene habilitado el método HTTP TRACE. Esta configuración puede ser aprovechada para ataques XST (Cross Site Tracing). Está clasificada como una vulnerabilidad de riesgo bajo que debe corregirse.

```
80/tcp    open  http          Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
|_http-methods:
|_ Potentially risky methods: TRACE
```

CONCLUSIÓN

- La auditoría realizada sobre el sistema **Windows Server 2019** ha permitido identificar una serie de servicios expuestos que, en conjunto, incrementan la superficie de ataque y podrían comprometer la seguridad del entorno si no se gestionan adecuadamente.
- La presencia de **servicios críticos como SMBv2, RDP y MSRPC** abiertos sin restricciones, así como protocolos como **NetBIOS**, representa un riesgo significativo, especialmente si no se acompañan de medidas de control como segmentación de red, autenticación reforzada y gestión de parches.
- El sistema presenta debilidades técnicas que deben ser corregidas para prevenir accesos no autorizados, fugas de información o escaladas de privilegios.
- Se recomienda aplicar una estrategia de **reducción de superficie de ataque**, junto con **parcheo proactivo, endurecimiento de configuraciones** y la implementación de **controles preventivos** como MFA, monitoreo de logs y listas de control de acceso. Con estas medidas, la organización podrá fortalecer su postura frente a amenazas internas y externas.